TRƯỜNG ĐẠI HỌC CÔNG NGHỆ ĐỒNG NAI (DNTU)
KHOA CÔNG NGHỆ THÔNG TIN – HỌC PHẦN WEB API (TH71108)

HƯỚNG DẪN THAO TÁC DEMO TRỰC TIẾP & KIỂM THỬ SWAGGER TOÀN DIỆN
HỆ THỐNG QUẢN LÝ HOẠT ĐỘNG HỘI NHẬP – VISIONARY

Tài liệu chuẩn bị cho 15 phút Thuyết trình & 10 phút Phản biện Cuối kỳ TH71108
Nhóm: VISIONARY API | Kịch bản chuỗi nghiệp vụ: Web Next.js -> Android Java -> WinForms C#

📌 **MỤC TIÊU VÀ NGUYÊN TẮC DEMO:** Tài liệu này hướng dẫn chi tiết từng cú nhấp chuột, từng tham số gửi lên Swagger, cách kích hoạt lỗi 401 Unauthorized và 403 Forbidden thật, quy trình CRUD chuẩn và quy trình đồng bộ dữ liệu xuyên suốt 3 nền tảng Web, Android, WinForms. Giúp nhóm làm chủ hoàn toàn buổi demo mà không gặp bất kỳ sự cố bất ngờ nào.

13.1. CHECKLIST CHUẨN BỊ TRƯỚC BUỔI DEMO (PRE-FLIGHT CHECKLIST)

Bước	Hạng mục kiểm tra	Yêu cầu kỹ thuật & Trạng thái mong đợi
1	Kiểm tra API Health & Live Server	Truy cập https://visionary-api-gb51.onrender.com/health trả về HTTP 200 'Healthy'.
2	Mở sẵn Swagger UI	Mở tab trình duyệt tại https://visionary-api-gb51.onrender.com/swagger, sẵn sàng thực thi.
3	Kiểm tra Web Client	Truy cập https://visionary-platform.vercel.app, đảm bảo trang chủ và tab sự kiện tải mượt mà.
4	Chuẩn bị tài khoản demo	Tài khoản BCN/Admin: committee_demo (vai trò Committee) | Tài khoản SV: student_demo (vai trò Student).
5	Khởi động Android Emulator	Bật Android Studio Virtual Device (Pixel API 34). Cài sẵn app-debug.apk (6.4 MB).
6	Khởi chạy Windows Forms	Mở sẵn file thực thi Visionary.Desktop.exe từ thư mục bin/Debug/net8.0-windows/.
7	Kiểm tra kết nối mạng (Wi-Fi)	Đảm bảo máy thuyết trình có kết nối internet ổn định hoặc 4G phát từ điện thoại.
8	Kiểm tra HTTPS & Chứng chỉ	Backend chạy HTTPS chuẩn trên

		Render có chứng chỉ SSL hợp lệ.
9	Kiểm tra Cơ sở dữ liệu Supabase	Kiểm tra kết nối PostgreSQL qua pooler cổng 5432 hoạt động bình thường.
10	Chuẩn bị dữ liệu demo an toàn	Có sẵn 1 sự kiện mẫu 'Hội thảo Kỹ năng Hội nhập Quốc tế' để SV đăng ký và BCN điểm danh.

13.2. CÁC ENDPOINT SWAGGER CHÍNH TRONG KỊCH BẢN DEMO

Phương thức	Đường dẫn Endpoint	Quyền yêu cầu	Thân yêu cầu (Body) / Query	Mã mong đợi
POST	/api/auth/login	Mở công khai	{"username": "...", "password": "..."}	200 OK + JWT
GET	/api/events	Mở công khai	?pageNumber=1&pageSize=10	200 OK + PagedResponse
GET	/api/events/{id}	Mở công khai	id: int trên đường dẫn	200 OK / 404
POST	/api/events	Admin, Committee	{"title": "...", "startDate": "...", "location": "..."}	201 Created
POST	/api/events/{id}/register	Đăng nhập (Student)	Bearer Token qua Header	200 OK / 400
POST	/api/events/{id}/attendance	Admin, Committee	{"studentId": 12, "attended": true}	200 OK

13.3. QUY TRÌNH DEMO LỖI 401 UNAUTHORIZED TRÊN SWAGGER

Mục đích: Chứng minh cơ chế bảo mật của Middleware ASP.NET Core khi client chưa xác thực danh tính.

Thao tác thực hiện trên Swagger:
1. Mở nhóm Events trên Swagger UI.
2. Tìm endpoint POST /api/events/{id}/register (Đăng ký tham gia sự kiện).
3. ĐẢM BẢO CHƯA BẤM NÚT 'Authorize' trên Swagger (chưa gắn token bất kỳ).
4. Điền tham số id = 1 và bấm nút 'Execute'.
5. Quan sát kết quả phản hồi:
   - HTTP Status Code: 401 Unauthorized.
   - Response Headers: WWW-Authenticate: Bearer error="invalid_token".
   - Ý nghĩa nghiệp vụ: Server từ chối ngay lập tức vì không xác định được ai đang đăng ký.

Mã nguồn minh chứng: Phản hồi HTTP 401 thực tế từ server khi không gửi Bearer token

```
HTTP/1.1 401 Unauthorized
Date: Sun, 26 Oct 2026 02:30:00 GMT
```

```
WWW-Authenticate: Bearer
Content-Length: 0
```

13.4. QUY TRÌNH DEMO LỖI 403 FORBIDDEN TRÊN SWAGGER

Mục đích: Chứng minh phân quyền Server-side (Role-based Authorization). Token hoàn toàn hợp lệ nhưng tài khoản không có quyền thực hiện nghiệp vụ quản trị.

Thao tác thực hiện trên Swagger:
1. Gọi POST /api/auth/login với tài khoản Sinh viên (student_demo).
2. Sao chép chuỗi token trong JSON phản hồi.
3. Bấm nút 'Authorize' (hình ổ khóa) ở góc trên Swagger, dán Bearer <token_sinh_vien> và bấm Authorize.
4. Tìm endpoint quản trị: POST /api/events (Tạo sự kiện mới) hoặc PUT /api/admin/users/{id}/roles.
5. Điền dữ liệu tạo sự kiện và bấm 'Execute'.
6. Quan sát kết quả phản hồi:
   - HTTP Status Code: 403 Forbidden.
   - Ý nghĩa nghiệp vụ: Server đã giải mã Token, nhận diện đúng sinh viên, nhưng thuộc tính [Authorize(Roles = "Admin,Committee")] từ chối quyền truy cập của vai trò Student.

Mã nguồn minh chứng: Phản hồi HTTP 403 thực tế từ server khi tài khoản không đủ quyền

```
HTTP/1.1 403 Forbidden
Date: Sun, 26 Oct 2026 02:31:00 GMT
Content-Length: 0
```

13.5. QUY TRÌNH KIỂM THỬ ĐẦY ĐỦ 4 THAO TÁC CRUD

Nghiệp vụ lựa chọn: QUẢN LÝ SỰ KIỆN (/api/events). Đây là nghiệp vụ chuẩn mực có đầy đủ Create, Read, Update, Delete/Cancel:
- Read (GET List): GET /api/events?pageNumber=1&pageSize=10 -> Nhận 200 OK + danh sách phân trang.
- Read (GET Detail): GET /api/events/{id} -> Nhận 200 OK chi tiết hoặc 404 Not Found nếu sai id.
- Create (POST): BCN đăng nhập -> POST /api/events kèm tiêu đề, ngày diễn ra -> Nhận 201 Created + Header Location: /api/events/{newId}.
- Update (PUT): BCN sửa thông tin sự kiện -> PUT /api/events/{id} -> Nhận 204 No Content (hoặc 200 OK).
- Delete/Cancel (DELETE/POST): Hủy hoặc đóng sự kiện -> Nhận 204 No Content. Gọi lại GET /api/events/{id} sẽ thấy trạng thái đã chuyển sang 'Cancelled'.

13.6. KỊCH BẢN DEMO PHỐI HỢP XUYÊN SUỐT 3 NỀN TẢNG (THE MASTER CHAIN)

Thứ tự	Người thao tác & Ứng dụng	Thao tác trực tiếp	Kết quả quan sát thấy

Chặng 1	Quách Khoa Đức (Website Next.js)	Mở trang Web, vào tab Sự kiện. Hiển thị sự kiện 'Hội thảo Kỹ năng Hội nhập Quốc tế' với 0 lượt đăng ký ban đầu.	Gọi GET /api/events thành công. Giao diện Web hiển thị thẻ Card trực quan.
Chặng 2	Đào Trí Khang (Android Emulator)	Sinh viên đăng nhập app Android. Mở chi tiết sự kiện 'Hội thảo Kỹ năng Hội nhập Quốc tế'. Bấm nút 'Đăng ký tham gia'.	Gọi POST /api/events/{id}/register. Nhận thông báo thành công và mã QR sinh ra.
Chặng 3	Võ Ngọc Minh Đạt (WinForms C#)	Ban Chủ nhiệm mở WinForms, chọn sự kiện trên DataGridView, bấm 'Xem danh sách đăng ký'. Thấy ngay sinh viên vừa đăng ký trên Android. Bấm 'Điểm danh'.	Gọi GET /api/events/{id}/registrations và POST .../attendance. Giao diện tick xanh thành công.
Chặng 4	Hồ Đoàn Nguyên Khang (Swagger UI)	Mở Swagger, gọi lại GET /api/events/{id} để kiểm chứng dữ liệu thật trong DB PostgreSQL. Số người tham gia tăng lên và trạng thái điểm danh khớp 100%.	Phản hồi JSON 200 OK xác nhận dữ liệu nhất quán trên cùng một Database.